PRAXISHANDBUCH

White Hat

Credo & Verhaltensregeln

Ein Handbuch für ethische Sicherheitsforschung

> *Technisches Können macht aus niemandem einen White Hat. Das tut erst die Haltung, mit der es eingesetzt wird.*
>
> AUS DEM VORWORT

AUTORISIERT HANDELN. VERANTWORTUNG TRAGEN. VERTRAUEN VERDIENEN.

Mit Checklisten, Fallbeispielen, Glossar und Kontaktstellen · Ausgabe Oktober 2026

White Hat Credo & Verhaltensregeln

Ein Handbuch für ethische Sicherheitsforschung

Credo, Verhaltensregeln, rechtlicher Rahmen, Checklisten und Fallbeispiele für Security-Forscher,
Penetration-Tester, Bug-Bounty-Jäger und Auszubildende im Bereich Cybersicherheit.

Inhaltsverzeichnis

Vorwort 4

Kapitel 2: Das Credo 4

Kapitel 3: Grundprinzipien 5

3.1 Autorisierung vor allem (Credo 1) 5

3.2 Scope ist Grenze (Credo 2) 5

3.3 Schaden vermeiden (Credo 3) 5

3.4 Daten sind kein Freiwild (Credo 4) 6

3.5 Transparenz gegenüber dem Auftraggeber (Credo 5) 6

3.6 Verantwortungsvolle Offenlegung (Credo 6) 6

3.7 Keine Eigennutzung (Credo 7) 6

3.8 Nachvollziehbarkeit (Credo 8) 6

3.9 Wissen verantwortungsvoll weitergeben (Credo 9) 6

Kapitel 4: Verhaltensregeln 6

4.1 Autorisierung und Scope (Credo 1, 2) 7

4.2 Umgang mit gefundenen Schwachstellen – Responsible Disclosure (Credo 3, 6, 7) 7

4.3 Datenschutz und Privatsphäre (Credo 3, 4) 7

4.4 Dokumentation und Berichterstattung (Credo 5, 8) 8

4.5 Kommunikation mit Auftraggebern (Credo 5) 8

Kapitel 5: Rechtlicher Rahmen 8

5.1 Strafrecht: §§ 202a–202c StGB 8

5.2 Datenschutz: DSGVO 9

5.3 Der Auftraggebervertrag 9

5.4 Weitere Regelwerke 9

Kapitel 6: Praktische Checklisten 9

6.1 Vor dem Engagement 10

6.2 Während des Engagements 10

6.3 Nach dem Engagement 10

Kapitel 7: Fallbeispiele 10

7.1 Ein unerwarteter Fund außerhalb des Scopes 11

7.2 Eine kritische Lücke kurz vor Projektende 11

7.3 Zufällig entdeckte personenbezogene Daten . . . 11
7.4 Eine Lücke nach Vertragsende . . . 11

Kapitel 8: Verstoß und Konsequenzen . . . 12

8.1 Interne Sanktionen . . . 12
8.2 Berufliche Folgen . . . 12
8.3 Selbstmeldung . . . 12

Kapitel 9: Anhang . . . 13

9.1 Glossar . . . 13
9.2 Hinweis zu Vertraulichkeitsvereinbarungen (NDA) . . . 13
9.3 Kontaktstellen . . . 14

Vorwort

Wer tief in fremde Systeme eindringen kann, trägt eine Verantwortung, die über reines technisches Können hinausgeht. Dieses Handbuch hält fest, woran sich ethische Sicherheitsforschung orientiert: als verbindliche Leitlinie für Security-Forscher:innen, Penetration-Tester:innen, Bug-Bounty-Jäger:innen und Auszubildende, und als Nachschlagewerk für den Arbeitsalltag. Teams und Einzelpersonen können es unverändert oder als Vorlage für ein eigenes, organisationsspezifisches Credo übernehmen.

Die Fähigkeiten eines White Hat unterscheiden sich technisch kaum von denen eines Angreifers. Der Unterschied liegt vollständig in der **Haltung**: in der Autorisierung, die jedem Test vorausgeht, in der Sorgfalt, mit der fremde Daten behandelt werden, und in der Bereitschaft, gefundene Schwachstellen verantwortungsvoll statt eigennützig zu behandeln. Diese Haltung lässt sich nicht aus einem Werkzeug ablesen. Sie muss gelernt, eingeübt und immer wieder bewusst gemacht werden.

Das Handbuch ist deshalb bewusst **kein technisches Lehrbuch**. Es enthält keine Anleitungen zu Angriffstechniken, keine Werkzeuge und keine Befehle. Es beschreibt stattdessen, wonach sich jede technische Entscheidung richten sollte: das Credo in Kapitel 2, die daraus abgeleiteten Verhaltensregeln in Kapitel 4, der rechtliche Rahmen in Kapitel 5 und die praktischen Checklisten in Kapitel 6.

> **Kernaussage**
>
> *„Technisches Können macht aus niemandem einen White Hat. Das tut erst die Haltung, mit der es eingesetzt wird.“*

Kapitel 2: Das Credo

Das Credo bündelt in neun Sätzen, woran sich jede Entscheidung im Verlauf eines Engagements messen lassen muss. Kapitel 3 erläutert jeden Punkt einzeln, Kapitel 4 übersetzt ihn in konkrete Verhaltensregeln.

1. **Autorisierung vor allem.** Ich handle ausschließlich mit ausdrücklicher, schriftlicher Erlaubnis des Systemeigentümers.
2. **Scope ist Grenze.** Ich bewege mich ausschließlich innerhalb des vereinbarten Rahmens und hole bei Zweifeln vorab Klärung ein.
3. **Schaden vermeiden.** Ich wähle unter mehreren Wegen zum Nachweis immer den mit dem geringsten Risiko für Systeme, Daten und Menschen.
4. **Daten sind kein Freiwild.** Ich greife nur auf Daten zu, die für den Nachweis einer Schwachstelle nötig sind, und behandle sie vertraulich.
5. **Transparenz gegenüber dem Auftraggeber.** Ich berichte ehrlich, vollständig und zeitnah – auch über eigene Fehler und Grenzen meiner Prüfung.
6. **Verantwortungsvolle Offenlegung.** Ich gebe Herstellern und Betreibern angemessene Zeit zur Behebung, bevor Details an Dritte gelangen.
7. **Keine Eigennutzung.** Ich nutze eine gefundene Schwachstelle niemals zum eigenen Vorteil und handle nicht mit ihr.

8. **Nachvollziehbarkeit.** Ich dokumentiere mein Vorgehen so, dass es jederzeit von Dritten nachvollzogen und überprüft werden kann.
9. **Wissen verantwortungsvoll weitergeben.** Ich teile Erkenntnisse so, dass sie die Sicherheit der Allgemeinheit stärken, statt Missbrauch zu erleichtern.

Diese neun Sätze stehen bewusst in dieser Reihenfolge: Die ersten beiden (Autorisierung, Scope) entscheiden, ob ein Test überhaupt stattfinden darf. Die mittleren (Schadensvermeidung, Datenschutz, Transparenz, Offenlegung) bestimmen, wie er abläuft. Die letzten drei (keine Eigennutzung, Nachvollziehbarkeit, Wissensweitergabe) betreffen das Verhalten danach.

> **Kernaussage**
>
> *„Jeder der neun Sätze lässt sich in eine einzige Frage übersetzen: Würde ich so handeln, wenn der Systemeigentümer dabei zusieht?“*

Kapitel 3: Grundprinzipien

Dieses Kapitel erläutert jeden Credo-Punkt mit einem kurzen, alltagsnahen Beispiel. Die Nummerierung entspricht der des Credos in Kapitel 2.

3.1 Autorisierung vor allem (Credo 1)

Autorisierung ist keine Formalie, sondern die Grenze zwischen beauftragter Sicherheitsforschung und einer Straftat (siehe Kapitel 5). Sie muss schriftlich vorliegen, bevor die erste technische Handlung erfolgt – nicht mündlich, nicht „wird schon passen“.

Beispiel: Ein Kunde bittet im Projektgespräch informell darum, „doch auch mal kurz die mobile App mitzutesten“. Ohne eine schriftliche Erweiterung des Auftrags bleibt die App außen vor, so naheliegend der Wunsch auch klingt.

3.2 Scope ist Grenze (Credo 2)

Der vereinbarte Scope legt fest, welche Systeme, IP-Bereiche und Methoden erlaubt sind. Er schützt Auftraggeber und Tester:innen gleichermaßen, weil beide Seiten wissen, woran sie sich halten.

Beispiel: Beim Scannen fällt ein offener Dienst auf einem System auf, das erkennbar zum selben Unternehmen gehört, aber nicht im Scope steht. Es wird nicht angetestet, sondern dem Auftraggeber als Hinweis gemeldet.

3.3 Schaden vermeiden (Credo 3)

Zwischen mehreren Wegen, eine Schwachstelle nachzuweisen, zählt nicht der eindrucksvollste, sondern der schonendste.

Beispiel: Eine SQL-Injection lässt sich nachweisen, ohne die komplette Kundendatenbank abzufragen – ein einzelner, harmloser Datensatz genügt als Beleg.

3.4 Daten sind kein Freiwild (Credo 4)

Zugriff auf Daten ist Mittel zum Nachweis, nicht Selbstzweck. Was nicht gebraucht wird, wird nicht angesehen, kopiert oder gespeichert.

Beispiel: Beim Zugriff auf ein E-Mail-Postfach als Nachweis einer Rechteausweitung werden nur Betreffzeilen zur Dokumentation genutzt, nicht die Inhalte einzelner Nachrichten.

3.5 Transparenz gegenüber dem Auftraggeber (Credo 5)

Ein ehrlicher Bericht über eine misslungene Testphase ist mehr wert als ein geschönter über einen vollständigen Erfolg.

Beispiel: Ein geplanter Testpfad erweist sich als nicht durchführbar. Das wird im Bericht offen benannt, statt es durch einen weniger aussagekräftigen Ersatzbefund zu kaschieren.

3.6 Verantwortungsvolle Offenlegung (Credo 6)

Zwischen Fund und Veröffentlichung liegt angemessene Zeit zur Behebung (siehe Kapitel 4.2 und 6).

Beispiel: Eine kritische Lücke wird dem Hersteller vertraulich gemeldet; ein Konferenzvortrag darüber wird erst nach Freigabe oder Ablauf der vereinbarten Frist gehalten.

3.7 Keine Eigennutzung (Credo 7)

Eine gefundene Schwachstelle ist niemals eine persönliche Gelegenheit.

Beispiel: Im Rahmen eines Tests werden Zugangsdaten sichtbar, die auch privat genutzt werden könnten. Sie werden ausschließlich im Bericht dokumentiert, niemals selbst ausprobiert.

3.8 Nachvollziehbarkeit (Credo 8)

Ein Befund ohne nachvollziehbaren Weg dorthin ist für den Auftraggeber kaum verwertbar.

Beispiel: Jeder Testschritt wird mit Zeitstempel, verwendetem Konto und Ergebnis protokolliert, sodass ein:e Kolleg:in den Weg später exakt nachvollziehen kann.

3.9 Wissen verantwortungsvoll weitergeben (Credo 9)

Wissen über Schwachstellenklassen stärkt die Allgemeinheit nur, wenn es so weitergegeben wird, dass es Verteidiger:innen mehr nützt als Angreifern.

Beispiel: Ein Vortrag über eine Schwachstellenklasse erklärt Ursache und Gegenmaßnahme ausführlich, verzichtet aber auf einen sofort einsatzfähigen Angriffscode gegen die betroffene Software.

> **Kernaussage**
>
> *„Jedes Prinzip bewährt sich erst in der konkreten Situation – deshalb zählt nicht, was im Credo steht, sondern wie danach gehandelt wird.“*

Kapitel 4: Verhaltensregeln

Die folgenden fünf Abschnitte übersetzen das Credo in konkrete Do's und Don'ts für den Arbeitsalltag. Jede Regel verweist auf den Credo-Punkt, aus dem sie folgt.

4.1 Autorisierung und Scope (Credo 1, 2)

Do	Don't
Vor Beginn einen unterschriebenen Vertrag mit Scope, Zeitfenster und Notfallkontakt einholen	Mit Tests beginnen, bevor die schriftliche Freigabe vorliegt
Scope-Grenzen bei Unklarheit aktiv beim Auftraggeber klären	Eine Grauzone im Scope eigenmächtig zugunsten des Tests auslegen
Entdeckte Systeme außerhalb des Scopes nur melden, nicht testen	„Nur kurz schauen“, ob ein Scope-fremdes System auch verwundbar ist
Änderungen am Scope schriftlich bestätigen lassen	Mündliche Scope-Erweiterungen als ausreichend behandeln

4.2 Umgang mit gefundenen Schwachstellen – Responsible Disclosure (Credo 3, 6, 7)

Do	Don't
Schwachstellen vertraulich und zeitnah an die zuständige Stelle melden	Eine Lücke öffentlich machen, bevor der Hersteller reagieren konnte
Dem Hersteller eine angemessene, im Vertrag oder Programm festgelegte Frist einräumen	Eigenmächtig eine „angemessene“ Frist nach eigenem Ermessen verkürzen
Nachweise so wählen, dass der geringstmögliche Eingriff nötig ist	Eine Lücke tiefer ausnutzen, als für den Nachweis nötig ist
Bei Unsicherheit über die Meldestelle offizielle Kanäle (CERT, Bug-Bounty-Programm) nutzen	Eine Lücke über private Kanäle Dritter „weitermelden“

4.3 Datenschutz und Privatsphäre (Credo 3, 4)

Do	Don't
Nur die Daten einsehen, die für den Nachweis zwingend nötig sind	Datenbanken oder Postfächer „aus Neugier“ durchsuchen
Personenbezogene Daten im Bericht anonymisieren oder pseudonymisieren	Echte Namen, Adressen oder Inhalte unverändert in den Bericht übernehmen
Zugriffsnachweise auf das technisch Nötige beschränken (z. B. ein Beispieldatensatz)	Vollständige Tabellen oder Postfächer exportieren
Gefundene Zugangsdaten ausschließlich dokumentieren	Gefundene Zugangsdaten selbst ausprobieren oder weiterverwenden

4.4 Dokumentation und Berichterstattung (Credo 5, 8)

Do	Don't
Jeden Testschritt mit Zeitpunkt, Methode und Ergebnis protokollieren	Nur das Endergebnis ohne Weg dorthin festhalten
Unklare oder fehlgeschlagene Testpfade ebenfalls dokumentieren	Nur erfolgreiche Befunde erwähnen
Befunde nach Risiko priorisieren und klar belegen	Befunde ohne nachvollziehbaren Beleg (Proof of Concept) aufnehmen
Rohdaten und Nachweise sicher und befristet aufbewahren	Nachweise unbegrenzt oder unverschlüsselt lagern

4.5 Kommunikation mit Auftraggebern (Credo 5)

Do	Don't
Kritische Funde sofort melden, nicht erst im Abschlussbericht	Eine kritische Lücke bis zum vereinbarten Berichtstermin zurückhalten
Erwartungen, Unsicherheiten und Grenzen der Prüfung offen benennen	Den Eindruck einer vollständigeren Prüfung erwecken, als tatsächlich erfolgt ist
Rückfragen des Auftraggebers zeitnah und verständlich beantworten	Fachbegriffe ohne Erklärung verwenden, wo Verständnis nötig ist
Vereinbarungen zu Vertraulichkeit und Weitergabe einhalten	Projektdetails ohne Freigabe mit Dritten teilen

> **Kernaussage**
>
> *„Jede Regel in diesem Kapitel ist nur die praktische Form eines der neun Credo-Sätze – wer das Credo verinnerlicht hat, leitet die meisten Regeln selbst her.“*

Kapitel 5: Rechtlicher Rahmen

Dieser Überblick ordnet die wichtigsten Rechtsgrundlagen ein, die jede Sicherheitsüberprüfung berührt.

> **Gut zu wissen**
>
> **Keine Rechtsberatung.** Dieses Kapitel ersetzt keine anwaltliche Prüfung im Einzelfall. Verträge und konkrete Engagements sollten vor Beginn rechtlich geprüft werden, insbesondere bei neuen Auftraggebern, grenzüberschreitenden Tests oder ungewöhnlichem Scope.

5.1 Strafrecht: §§ 202a–202c StGB

- **§ 202a StGB (Ausspähen von Daten):** Der unbefugte Zugriff auf besonders gesicherte Daten ist strafbar, unabhängig davon, ob ein Schaden entsteht. Eine schriftliche Autorisierung (Credo 1) macht den Zugriff befugt.
- **§ 202b StGB (Abfangen von Daten):** Betrifft das unbefugte Abfangen von Daten aus nicht öffentlicher Übermittlung, etwa beim Mitschneiden von Netzwerkverkehr.

- **§ 202c StGB (Vorbereiten des Ausspähens und Abfangens von Daten):** Erfasst das Herstellen oder Verbreiten von Werkzeugen, deren Zweck eine Tat nach § 202a/§ 202b ist, verbunden mit Vorsatz zur Begehung einer solchen Tat. Der autorisierte Einsatz derselben Werkzeuge im Rahmen eines Auftrags erfüllt diesen Tatbestand nicht.

5.2 Datenschutz: DSGVO

Nahezu jeder Test berührt personenbezogene Daten – Logins, Kundendatenbanken, Mitarbeiterkonten. Das wirkt sich auf zwei Ebenen aus:

- **Rechtsgrundlage:** Der Auftraggeber braucht eine Rechtsgrundlage für die Verarbeitung im Rahmen des Tests, häufig ergänzt um eine Vereinbarung zur Auftragsverarbeitung (AVV) mit dem Testteam.
- **Datenminimierung:** Credo 4 (Daten sind kein Freiwild) ist nicht nur ethischer Grundsatz, sondern deckt sich mit dem datenschutzrechtlichen Prinzip, nur so viele Daten wie nötig zu verarbeiten.

5.3 Der Auftraggebervertrag

Der Vertrag ist die rechtliche Grundlage, auf der das gesamte Credo aufbaut. Er sollte mindestens enthalten:

1. **Scope:** Systeme, IP-Bereiche, Anwendungen – eingeschlossen und ausdrücklich ausgeschlossen.
2. **Zeitfenster:** Wann getestet werden darf.
3. **Erlaubte Methoden:** Ob z. B. Denial-of-Service-Tests oder Social Engineering erlaubt sind.
4. **Notfallkontakt:** Wer bei einem unerwarteten Vorfall sofort informiert wird.
5. **Freistellungserklärung** (Get-out-of-jail-free letter): schriftliche Bestätigung, die im Ernstfall gegenüber Behörden vorgelegt werden kann.
6. **Vertraulichkeits- und Weitergaberegeln**, einschließlich Umgang mit gefundenen Daten und Fristen für eine Offenlegung (siehe Kapitel 4.2 und 9.2).

5.4 Weitere Regelwerke

Je nach Branche und Auftraggeber kommen weitere Vorgaben hinzu, etwa branchenspezifische Sicherheitsstandards, interne Richtlinien des Auftraggebers oder – bei kritischen Infrastrukturen – zusätzliche gesetzliche Melde- und Sorgfaltspflichten. Diese sind vor Vertragsabschluss zu klären.

> **Kernaussage**
>
> *„Der Vertrag ist kein Hindernis für die Arbeit, sondern ihre Voraussetzung: Ohne ihn ist dieselbe Handlung, die beauftragt legal wäre, unbefugt und potenziell strafbar.“*

Kapitel 6: Praktische Checklisten

Die drei Checklisten begleiten ein Engagement von der Vorbereitung bis zum Abschluss und fassen die Kapitel 2 bis 5 in prüfbarer Form zusammen.

6.1 Vor dem Engagement

1. Liegt ein unterschriebener Vertrag mit definiertem Scope vor? (Kapitel 5.3)
2. Sind Ziel-Systeme, ausgeschlossene Bereiche und Zeitfenster eindeutig benannt?
3. Ist ein Notfallkontakt beim Auftraggeber erreichbar?
4. Liegt eine Freistellungserklärung vor?
5. Sind erlaubte Methoden (z. B. Denial-of-Service, Social Engineering) ausdrücklich geklärt?
6. Ist die datenschutzrechtliche Grundlage (AVV, Rechtsgrundlage) geklärt?
7. Ist das Testteam über Credo und Verhaltensregeln informiert?

6.2 Während des Engagements

1. Bleibt jede Handlung innerhalb des vereinbarten Scopes? (Kapitel 4.1)
2. Wird bei jedem Test der schonendste Nachweisweg gewählt? (Kapitel 4.3)
3. Werden nur die für den Nachweis nötigen Daten eingesehen? (Kapitel 4.3)
4. Wird jeder Schritt mit Zeitpunkt, Methode und Ergebnis dokumentiert? (Kapitel 4.4)
5. Werden kritische Funde sofort gemeldet, nicht erst am Projektende? (Kapitel 4.5)
6. Werden unklare oder fehlgeschlagene Testpfade ebenfalls festgehalten?
7. Bleiben gefundene Zugangsdaten unberührt, abgesehen von der Dokumentation?

6.3 Nach dem Engagement

1. Ist der Bericht vollständig, ehrlich und nach Risiko priorisiert? (Kapitel 4.4)
2. Sind alle Befunde mit nachvollziehbarem Beleg versehen?
3. Ist eine angemessene Offenlegungsfrist mit dem Hersteller oder Auftraggeber vereinbart? (Kapitel 4.2)
4. Sind Rohdaten und Nachweise sicher und befristet gespeichert, nicht unbegrenzt?
5. Wurden temporäre Zugänge und angelegte Testkonten zurückgebaut oder deaktiviert?
6. Ist ein Retest nach Behebung der Befunde vereinbart?
7. Wurde das Projekt intern nachbesprochen, einschließlich offener Lernpunkte?

> **Kernaussage**
>
> *„Eine Checkliste ersetzt kein Urteilsvermögen – aber sie verhindert, dass unter Zeitdruck ausgerechnet der entscheidende Schritt übersprungen wird.“*

Kapitel 7: Fallbeispiele

Die folgenden vier Szenarien sind anonymisiert und vereinfacht. Sie zeigen jeweils ein Verhalten im Einklang mit dem Credo und ein Verhalten dagegen, mit den jeweiligen Konsequenzen.

7.1 Ein unerwarteter Fund außerhalb des Scopes

Situation: Während eines beauftragten Webtests fällt ein offener, erkennbar zum selben Unternehmen gehörender Server auf, der nicht im Scope steht.

Verhalten im Einklang mit dem Credo	Verhalten dagegen
Der Fund wird dem Auftraggeber als Hinweis gemeldet, ohne weiter getestet zu werden (Credo 1, 2).	Der Server wird „nur kurz“ mitgetestet, weil es „doch zum selben Projekt gehört“.
Konsequenz: Der Auftraggeber erweitert bei Bedarf schriftlich den Scope; Vertrauen bleibt erhalten.	**Konsequenz:** Ein Test ohne Autorisierung – unabhängig vom Ergebnis ein Vertragsbruch und möglicher Straftatbestand (Kapitel 5.1).

7.2 Eine kritische Lücke kurz vor Projektende

Situation: Zwei Tage vor dem geplanten Abschlussbericht wird eine kritische, leicht ausnutzbare Schwachstelle gefunden.

Verhalten im Einklang mit dem Credo	Verhalten dagegen
Der Fund wird sofort, nicht erst im Abschlussbericht, gemeldet (Credo 5).	Der Fund wird zurückgehalten, um ihn „wirkungsvoll“ im Abschlussbericht zu präsentieren.
Konsequenz: Der Auftraggeber kann sofort reagieren, Schaden wird minimiert.	**Konsequenz:** Unnötiges Zeitfenster für reale Angreifer, Vertrauensverlust bei Bekanntwerden der Verzögerung.

7.3 Zufällig entdeckte personenbezogene Daten

Situation: Beim Testen einer Rechteausweitung wird Zugriff auf ein Postfach mit privater Kommunikation von Mitarbeitenden sichtbar.

Verhalten im Einklang mit dem Credo	Verhalten dagegen
Nur die Tatsache des Zugriffs und ein anonymisierter Beleg werden dokumentiert; Inhalte werden nicht gelesen (Credo 4).	Einzelne Nachrichten werden aus Neugier gelesen oder gar zitiert.
Konsequenz: Nachweis bleibt vollständig, Persönlichkeitsrechte bleiben gewahrt.	**Konsequenz:** Verstoß gegen Datenschutz und Credo, möglicher eigenständiger Rechtsverstoß unabhängig vom ursprünglichen Auftrag.

7.4 Eine Lücke nach Vertragsende

Situation: Monate nach Projektabschluss fällt auf, dass eine damals gemeldete Lücke offenbar nie behoben wurde.

Verhalten im Einklang mit dem Credo	Verhalten dagegen
Der Auftraggeber wird erneut, vertraulich und unter Verweis auf den ursprünglichen Befund informiert (Credo 6).	Die Lücke wird öffentlich gemacht, um Druck auf den Auftraggeber auszuüben.
Konsequenz: Dem Auftraggeber bleibt die Möglichkeit zur Behebung; die professionelle Beziehung bleibt intakt.	**Konsequenz:** Reale Nutzer:innen werden gefährdet, bevor ein Fix existiert; Vertrauensbruch gegenüber dem ursprünglichen Auftraggeber.

> **Kernaussage**

> *„In jedem der vier Fälle unterscheidet sich die gute von der schlechten Entscheidung nicht durch mehr technisches Können, sondern durch die Bereitschaft, kurzfristig unbequem zu handeln.“*

Kapitel 8: Verstoß und Konsequenzen

Ein Credo ohne Konsequenzen bleibt eine Absichtserklärung. Dieses Kapitel beschreibt, wie mit Verstößen umgegangen wird – intern wie extern.

8.1 Interne Sanktionen

Schweregrad	Beispiel	Mögliche interne Folge
Gering	Dokumentation unvollständig, Formfehler im Bericht	Nachbesserung, Feedbackgespräch
Mittel	Scope versehentlich überschritten, ohne Schaden	Nachschulung, verschärfte Freigabeprozesse für folgende Projekte
Schwer	Vorsätzliche Eigennutzung einer Schwachstelle, bewusster Scope-Bruch	Abberufung vom Projekt, arbeitsrechtliche Konsequenzen bis zur Kündigung
Sehr schwer	Unautorisierter Zugriff außerhalb jedes Auftrags, Datenmissbrauch	Meldung an Auftraggeber und ggf. Strafverfolgungsbehörden, fristlose Kündigung

Die Einstufung berücksichtigt sowohl die Schwere der Handlung als auch, ob sie vorsätzlich oder fahrlässig geschah, und ob sie selbst gemeldet oder erst entdeckt wurde.

8.2 Berufliche Folgen

Verstöße gegen Credo und Verhaltensregeln bleiben selten folgenlos für die berufliche Laufbahn:

- **Vertrauensverlust** bei Auftraggebern, der über das einzelne Projekt hinausreicht.
- **Zertifizierungen und Programmausschluss:** Bug-Bounty-Plattformen und Berufsverbände können bei schweren Verstößen Konten sperren oder ausschließen.
- **Strafrechtliche Konsequenzen** (Kapitel 5.1), die unabhängig von internen Sanktionen bestehen bleiben.
- **Reputationsschaden** in einer vergleichsweise kleinen Fachcommunity, in der sich Verstöße herumsprechen.

8.3 Selbstmeldung

Ein eigener Fehler, der selbst gemeldet wird, wird grundsätzlich anders bewertet als ein Verstoß, der erst durch Dritte auffällt. Wer merkt, versehentlich den Scope verlassen oder mehr Daten als nötig eingesehen zu haben, meldet dies umgehend dem eigenen Team und dem Auftraggeber.

> **Kernaussage**

> *„Die schärfste Konsequenz trifft nicht den ehrlichen Fehler, sondern den Versuch, ihn zu verbergen.“*

Kapitel 9: Anhang

Der Anhang ergänzt das Handbuch um Begriffsklärungen, einen Hinweis zu Vertraulichkeitsvereinbarungen und zentrale Kontaktstellen.

9.1 Glossar

- **Bug Bounty** – Programm, das Finder:innen von Schwachstellen gegen Prämie zur Meldung einlädt.
- **Engagement** – ein einzelnes, beauftragtes Projekt der Sicherheitsüberprüfung mit definiertem Zeitraum und Scope.
- **Freistellungserklärung (Get-out-of-jail-free letter)** – schriftliche Bestätigung des Auftraggebers, die im Ernstfall gegenüber Behörden vorgelegt werden kann.
- **Pentest (Penetrationstest)** – autorisierte, simulierte Angriffsprüfung gegen definierte Zielsysteme.
- **Proof of Concept** – ein nachvollziehbarer Beleg dafür, dass eine Schwachstelle tatsächlich ausnutzbar ist.
- **Responsible Disclosure** – koordinierte, vertrauliche Meldung einer Schwachstelle mit angemessener Frist zur Behebung vor einer möglichen Veröffentlichung.
- **Retest** – eine gezielte Nachprüfung nach Behebung gemeldeter Schwachstellen.
- **Scope** – der vertraglich definierte Umfang eines autorisierten Tests: Systeme, Zeitfenster, erlaubte Methoden.
- **White Hat** – eine Sicherheitsfachkraft, die ausschließlich mit schriftlicher Autorisierung testet.

9.2 Hinweis zu Vertraulichkeitsvereinbarungen (NDA)

Ein **NDA** (Non-Disclosure Agreement, Vertraulichkeitsvereinbarung) regelt, welche während eines Engagements bekannt gewordenen Informationen nicht an Dritte weitergegeben werden dürfen. Es ergänzt den Auftraggebervertrag (Kapitel 5.3) und betrifft typischerweise:

- Details zu gefundenen Schwachstellen vor ihrer Behebung,
- interne Systeminformationen und Architekturdetails,
- personenbezogene oder geschäftskritische Daten, die während des Tests sichtbar wurden.

> **Gut zu wissen**
>
> Ein NDA ist ein eigenständiges juristisches Dokument. Dieses Handbuch beschreibt nur, wofür es typischerweise steht – die konkrete Formulierung und Reichweite sollte im Einzelfall rechtlich geprüft werden (keine Rechtsberatung, siehe Kapitel 5).

9.3 Kontaktstellen

Stelle	Zuständigkeit
BSI (Bundesamt für Sicherheit in der Informationstechnik)	nationale Cybersicherheitsbehörde Deutschlands; Meldewege für Schwachstellen und Vorfälle
CERT-Bund	das Computer Emergency Response Team des Bundes, angesiedelt beim BSI; koordiniert Reaktionen auf IT-Sicherheitsvorfälle
Zuständige Landes- oder Bundespolizei	bei Verdacht auf strafbare Handlungen im Zusammenhang mit IT-Sicherheit
Betrieblicher oder behördlicher Datenschutzbeauftragter	bei Fragen zur Verarbeitung personenbezogener Daten während eines Tests

> **Kernaussage**
>
> *„Wer im Zweifel ist, ob eine Situation die eigene Zuständigkeit übersteigt, wendet sich an eine dieser Stellen – das ist kein Zeichen von Unsicherheit, sondern von Sorgfalt.“*

WHITE HAT CREDO & VERHALTENSREGELN

Neun Sätze, an denen sich jede Entscheidung messen lässt

Technisches Können unterscheidet einen White Hat kaum von einem Angreifer. Der Unterschied liegt in der Haltung: in der Autorisierung, die jedem Test vorausgeht, im Umgang mit fremden Daten und in der Bereitschaft, gefundene Schwachstellen verantwortungsvoll zu behandeln. Dieses Handbuch hält Credo, Verhaltensregeln, rechtlichen Rahmen und Checklisten verbindlich fest – als Leitfaden für den Arbeitsalltag und als Vorlage für ein eigenes Team-Credo.

DAS ERWARTET DICH

- Das Credo: neun prägnante Leitsätze als gemeinsamer Kompass
- Verhaltensregeln als Do/Don't-Tabellen zu Scope, Disclosure, Datenschutz und Reporting
- Rechtlicher Rahmen: StGB §§ 202a-202c, DSGVO, Auftraggebervertrag
- Checklisten für vor, während und nach jedem Engagement
- 4 Fallbeispiele gut/schlecht, Konsequenzen bei Verstößen, Glossar und Kontaktstellen

Für wen?

Security-Forscher:innen, Penetration-Tester:innen, Bug-Bounty-Jäger:innen und Auszubildende im Bereich Cybersicherheit. Als Leitlinie und Nachschlagewerk gedacht, nicht als technisches Lehrbuch.

14 Seiten · Stand Oktober 2026 · Für Security-Forscher:innen, Pentester:innen und Auszubildende

Hinweis: Keine Rechts- oder Anlageberatung. Marken- und Produktnamen gehören ihren jeweiligen Inhabern.